医疗影像安全完整必备功能（适配PACS、影像采集终端、云影像、符合YY/T1861、等保2.0、个保法、DICOM PS3.15）

整体分为**身份访问安全、DICOM通信安全、数据加密与完整性、隐私脱敏去标识、操作审计追溯、存储容灾备份、终端与网络安全、数据生命周期管控、安全应急与合规、设备辐射安全**十大模块。

> 本清单为**能力全景**；各条的落地优先级、验收口径见文末「极简落地优先级」与「验收标准（用户视角）」。

文档信息

项目	内容
文档性质	产品/系统**安全需求清单**（描述"要什么"），不含实现方案
适用对象	PACS、影像采集工作站、云影像/远程会诊平台、AI 辅助诊断前置系统
适用系统	Windows；银河麒麟 V10/V11（x86_64、aarch64）；主流 Linux 服务器
合规参考	《个人信息保护法》《数据安全法》《基本医疗卫生与健康促进法》；**YY/T 1861**、**等保2.0（三级）**、**DICOM PS3.15**（安全轮廓/去标识）；国密算法与密评要求
核心定位	覆盖影像数据的**接入—传输—存储—使用—共享—销毁**全链路安全与合规能力
明确边界	本篇为安全能力需求，**不替代** PACS/HIS/RIS 业务功能，也不替代等保测评、密评与医院制度的最终认定（见「非目标与范围边界」）

一、可信身份与细粒度访问控制（源头防越权）

1. 多因素强身份认证

1. 支持**账号密码+UKey/数字证书（国密SM2）/指纹/人脸/动态验证码**二/三因子登录，禁止单一弱密码登录；
2. 密码复杂度策略：长度≥8位，大小写+数字+特殊字符，定期强制更换、锁定多次失败账号；

3. 统一4A身份对接，院内HIS/RIS/PACS账号互通，实习/进修人员限时临时账号、到期自动回收权限。

2. DICOM节点鉴权（设备通信准入）

- 可配置合法AE Title、IP、端口白名单，拒绝未知设备C-STORE/C-MOVE/C-FIND请求；
- 按设备区分权限：仅允许CT/MRI上传，不允许任意设备下载、删除影像。

3. RBAC最小权限管控

- 角色分级：技师（仅上传）、诊断医师（调阅+写报告）、科主任（批量导出/审批）、管理员（系统配置，不可查看患者影像）、科研（仅脱敏数据）；
- 字段级权限：普通医生仅看本院患者，跨院会诊需人工审批；可限制仅能查看自身分管患者；
- 临时授权机制：会诊、教学可发放限时临时权限，到期自动失效，支持一键撤销。

二、DICOM通信传输安全（防窃听、中间人篡改）

1. **DICOM TLS加密传输**（DICOM PS3.15标准），院内、跨院、远程访问全部启用TLS1.3，禁止明文DICOM通信；
2. 远程访问支持国密SSL/VPN隧道，公网会诊不走裸DICOM端口；
3. 通信完整性校验：DICOM数据流传输前后校验MD5/SM3哈希，中途篡改直接丢弃重传；
4. 端口管控：关闭DICOM默认开放高危端口，仅白名单IP放行；防火墙隔离放射内网与办公外网。

三、全链路数据加密（静态存储+动态传输，国密合规）

1. 存储静态加密

- 影像文件全盘/文件级加密，优先**国密SM4**，兼容AES256；DICOM原始文件落盘自动加密，硬盘失窃无法读取原始影像；
- 密钥全生命周期管理：硬件加密机存储密钥、定期轮换、双人保管根密钥，禁止硬编码密钥；
- 数据库元数据（患者姓名、身份证、检查记录）字段加密存储。

2. 传输动态加密

- 内网DICOM TLS、外网会诊国密VPN、Web阅片HTTPS/TLS1.3；
- 离线导出（U盘/光盘）：导出包加密，需授权密码打开，禁止明文拷贝原始DICOM。

3. 完整性防篡改

- DICOM文件附加SM3数字签名，任意修改像素/头文件信息即可校验失败；
- 关键报告、诊断记录支持电子签章（国密SM2签名），不可篡改、不可抵赖。

四、患者隐私保护：脱敏、去标识、水印（满足《个人信息保护法》）

1. DICOM头文件自动脱敏/去标识化

- 自动清除/替换敏感字段：姓名、身份证、手机号、住址、出生日期、医保号；
- 区分两种模式：
  1）临时会诊脱敏：仅隐藏敏感信息，保留唯一关联ID，可溯源；
  2）科研匿名化：彻底剥离所有标识，无法反向关联患者；
- 支持手动脱敏、批量脱敏，导出/共享前强制脱敏校验，未脱敏禁止外传。

2. 图像数字水印（不可移除溯源）

1. 明水印：右下角嵌入患者编号、机构、操作人；
2. 隐形鲁棒水印：嵌入像素底层，截图、裁剪、导出后仍可提取操作者、时间、设备信息；
3. 离线拷贝、截图、打印自动追加水印，防止私自外传泄露。

3. 打印管控

- 打印影像自带水印，记录打印人、时间；禁止无授权批量打印；打印日志留存审计。

五、全行为审计追溯（等保强制要求，日志留存≥6个月，核心数据≥3年）

1. **全操作日志记录**：
   登录登出、影像上传/调阅/下载/删除/打印、报告修改、跨院会诊导出、权限变更、系统配置、批量删除、脱敏操作；
2. 日志字段完整：操作人、账号、终端IP、设备AE、患者ID、影像序列、操作时间、操作结果；
3. 日志防篡改：日志库独立存储、只读、不可删除，支持区块链存证；
4. 审计检索：按患者、人员、时间、操作类型快速溯源；
5. 异常行为自动告警：批量下载、异地多次调阅、非工作时间大量访问、多次失败登录。

六、存储容灾与数据生命周期安全（防丢失、勒索病毒）

1. **多副本冗余存储**：在线RAID5/6、近线归档、离线备份三级架构，杜绝单点故障；
2. 定时自动备份：每日增量、每周全量，**异地灾备**（跨机房/跨院区）；
3. 备份恢复演练：每季度抽样恢复校验，确保勒索病毒、硬件损坏后可完整找回影像；
4. 数据生命周期管理：
   - 短期在线（1–3年）快速调阅；中长期归档至低成本存储；
   - 到期数据按法规自动归档/离线封存，销毁支持不可逆粉碎删除；
5. 防勒索防护：存储读写权限隔离，禁止PACS服务器直接外网访问，定期快照回滚。

七、终端与外接设备安全（采集工作站、阅片电脑）

1. 终端准入：放射工作站IP/MAC绑定，外来电脑禁止接入影像内网；
2. 外设管控：限制USB只读，导出影像必须走系统加密导出通道，禁止直拷原始DICOM；
3. 终端安全：统一杀毒、补丁更新，屏幕防截屏水印、远程阅片禁止本地缓存原始影像；
4. 移动设备（平板/手机阅片）：APP加密缓存、退出自动清缓存、远程设备销毁功能。

八、数据共享与对外交互安全（医联体、远程会诊、科研）

1. 跨机构共享审批流程：申请→科室主任审批→自动脱敏→加密传输→操作留痕；
2. 数据使用边界管控：科研数据仅允许脱敏影像，禁止带出医院原始标识；
3. 第三方接口安全（HIS、AI辅助诊断、医保）：接口鉴权、请求频率限流、数据输出脱敏、接口日志审计；
4. 禁止原始影像无限制对外输出，所有对外分发均可溯源。

九、安全监测、告警与应急处置

1. 实时流量监测：DICOM异常大量传输、陌生IP访问、批量下载实时告警；
2. 入侵检测IDS/IPS：识别暴力破解、端口扫描、恶意篡改DICOM数据流；
3. 安全事件闭环：泄露/越权访问自动生成处置工单，留存处置记录；
4. 应急机制：勒索病毒隔离、账号紧急冻结、可疑病例访问一键阻断。

十、合规配套管理功能（满足医卫数据安全办法、YY/T1861、等保三级）

1. 安全策略配置中心：统一开关加密、水印、脱敏、日志、访问白名单；

2. 安全自查报表：权限审计、异常访问统计、备份有效性、脱敏记录；
3. 操作人安全培训记录、外部服务商访问审批与保密协议管理；
4. 国密算法合规适配、密评支撑功能；
5. 分级分类管理：区分核心/重要/一般医疗影像数据，差异化防护强度。

十一、放射设备物理辐射安全（影像设备硬件安全，配套软件联动）

1. 机房联锁、射线曝光状态指示灯、电离辐射警示；
2. 扫描剂量记录留存，符合ALARA低剂量原则；
3. 设备故障自动停机、剂量超阈值告警，人员防护管理记录。

十二、系统健壮性与高可用（安全能力自身不能成为故障源）

安全模块一旦失效不得拖垮临床业务；故障时应"降级并告警"，而非"整体不可用"。

1. **故障隔离与降级**：认证、加密、审计、水印等模块各自隔离，单模块异常只暂停相关能力并告警，阅片/采图主链路尽量不受影响；
2. **关键路径可用性**：密钥服务/CA/时间源短时不可用时，已有会话与在途检查可继续，禁止因外部依赖抖动导致检查中断；
3. **时钟与时间源**：审计时间戳依赖 NTP，时间源异常须告警；时间跳变不得造成日志乱序或留存期误判；
4. **容量与性能**：加密、水印、脱敏对单次影像写入/调阅的附加延迟可控，不显著抢占采集写入带宽；日志与审计存储具备滚动/归档能力，不允许因日志写满导致业务盘满；
5. **升级与迁移不破坏合规**：升级、重装、迁移不得无提示清空密钥、审计日志与备份；密钥与审计数据结构变更须可平滑迁移；
6. **恢复后一致性**：断电或进程重启后，未完成的加密写入、审计落库、备份任务可续做，且不产生"已审计/未审计"的歧义记录。

十三、非目标与范围边界（避免验收歧义）

不做 / 不承诺	说明
不承担临床诊断、报告书写、完整 PACS/HIS/RIS 业务	本清单只覆盖安全与合规能力

不做 / 不承诺	说明
不替代等保测评、密评与第三方审计结论	提供能力与证据， 最终认定由测评机构与医院制度决定
不保证任意私有格式、 加密容器的深度解析与脱敏	DICOM 脱敏依赖可解析的标准字段； 私有封装需另行约定
不提供对抗性"去水印"、未授权数据恢复能力	水印与加密仅作合规溯源与防护
不承诺对抗具备系统管理员权限的攻击者	目标是提高攻击成本、留下可追溯证据
不默认向公网传输业务数据	对外交互一律走审批 + 加密通道

十四、验收标准（用户视角）

编号	验收项
A01	多因子登录可演示：弱密码/单因子被拒；连续失败锁定；临时账号到期自动失效
A02	未知 AE Title / 非白名单 IP 的 C-STORE、C-FIND、C-MOVE 请求被拒绝并留痕
A03	明文 DICOM 通信被拒；院内与跨院链路均为 TLS1.3；抓包不可见患者信息明文
A04	影像落盘后直接拷贝文件无法解读；密钥与影像不在同一物理位置、无硬编码密钥
A05	篡改任一像素或头字段后，SM3 校验/签名校验失败并可定位
A06	临时会诊脱敏保留可溯源关联 ID；科研匿名化后无法反向关联；未脱敏导出被拦截并告警
A07	截图、打印、离线拷贝的影像均可提取出操作人、时间、设备水印
A08	登录、调阅、下载、删除、打印、导出、权限变更、配置变更均有审计记录且字段完整
A09	审计日志不可被业务清理删除；导出审计记录可用于纠纷调阅
A10	批量下载、非工作时间大量访问、异地多次调阅可触发告警并生成处置工单
A11	抽样恢复演练可完整找回影像；勒索/硬件损坏场景下备份可用
A12	外接设备直拷原始 DICOM 被阻断；移动端退出后本地无残留原始影像
A13	跨机构共享走完"申请→审批→脱敏→加密传输→留痕"流程；所有对外分发可溯源
A14	安全策略配置中心的开关（加密/水印/脱敏/日志/白名单）改动记审计并即时生效

编号	验收项
A15	单模块故障（如密钥服务短时不可用）不导致检查中断，降级并告警
A16	升级/重装后密钥、审计日志、备份数据完整保留，任务可续做

极简落地优先级（开发/产品选型参考）

1. 必做（等保+法规硬性）：身份多因子、DICOM TLS加密、操作审计日志、存储加密、水印脱敏、AE/IP白名单、备份容灾；
2. 进阶（三甲/云影像）：国密套件、数字签名、临时授权、异地灾备、异常行为告警；
3. 高阶（科研/医联体）：区块链存证、联邦学习脱敏、细粒度跨院共享审批。

需求条目优先级映射

优先级	覆盖条目	说明
P0（必做）	一.1/一.2、二.1/二.4、三.1、四.1、五.1–五.3、六.1–六.2、十二.1/十二.5	等保与法规硬性项，缺失即不合规
P1（进阶）	一.3、二.2/二.3、三.2/三.3、四.2、五.4/五.5、六.3–六.5、七.1–七.3、八.1、九.1–九.4	三甲 / 云影像场景的标配能力
P2（高阶）	四.3、七.4、八.2–八.4、十.1–十.5、十一、十二.2–十二.4/十二.6	科研 / 医联体 / 深度合规运营阶段

> 优先级为**建议基线**，具体排期需结合医院制度、测评结论与合同约定调整。